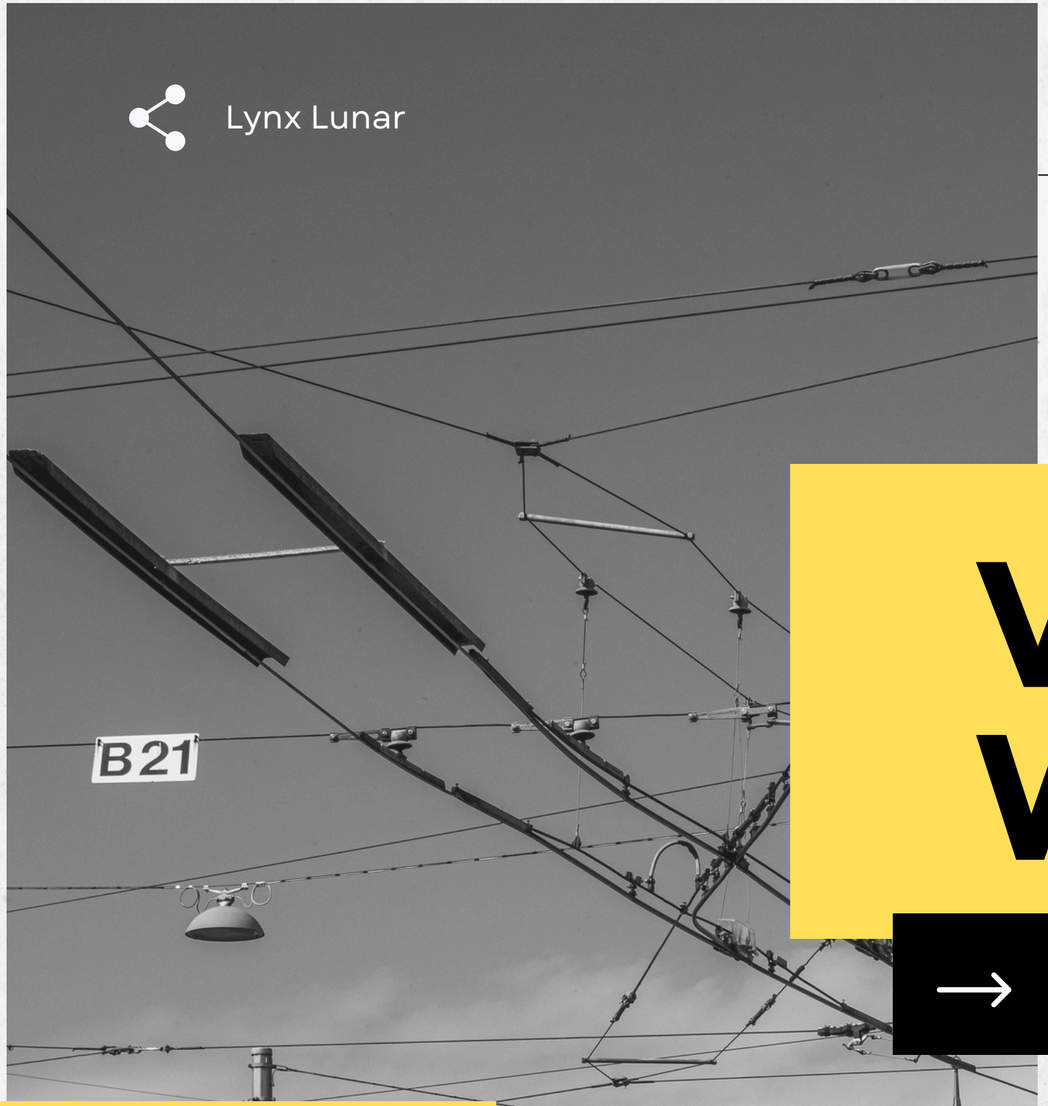


Vanguard Web Defense

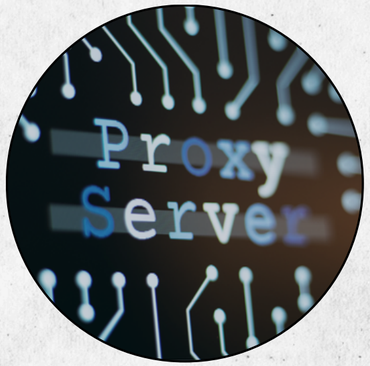
Course Project for 88633065 Computer Networks

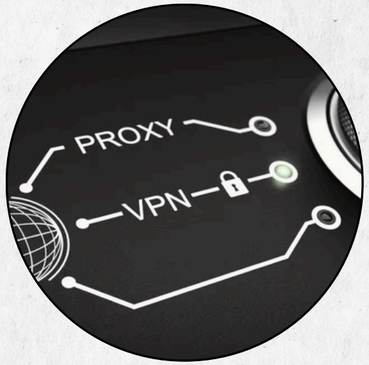


https://lynxlunarcs.duckdns.org/

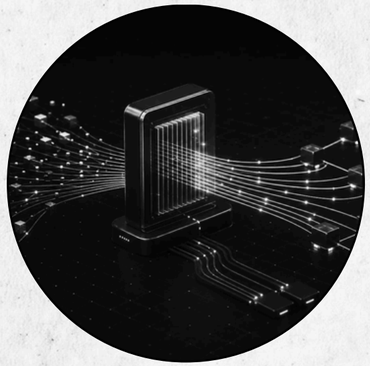
เป้าหมาย

การสร้างสภาพแวดล้อมดิจิทัลที่มีความปลอดภัยสูงผ่านการบูรณาการเกราะป้องกันในทุกระดับชั้น เริ่มจากการควบคุมช่องทางเข้า-ออกเครือข่ายและการบล็อกผู้บุกรุกตั้งแต่ขอบนอก การตรวจสอบและแจ้งเตือนพฤติกรรมผิดปกติในระดับเซิร์ฟเวอร์เพื่อป้องกันการลักลอบเข้าสู่ระบบ การกรองคำขอและสกัดกั้นการโจมตีเว็บในส่วนของหน้าบ้าน ตลอดจนการป้องกันฟอร์มและฐานข้อมูลจากบอทประสงค์ร้าย เพื่อปกป้องข้อมูลสำคัญขององค์กรและผู้ใช้งานจากการถูกเจาะระบบหรือรั่วไหลออกสู่สาธารณะ









โครงสร้างสถาปัตยกรรม

Perimeter & Network Layer
DuckDNS -> Azure NSG -> Firewall & IPset

↓ รับทราฟฟิกผ่านพอร์ต 80, 443

Host & OS Security Layer
Ubuntu -> SSH Key Authentication
Fail2Ban & AI Log Analysis

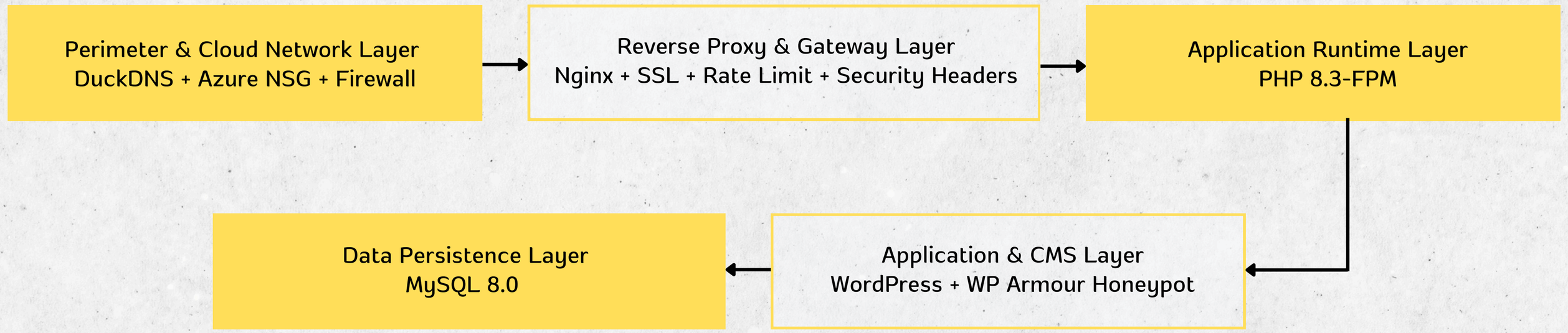
↓ Nginx และ PHP-FPM ทำงานบน Ubuntu VM

Application Runtime & Web Server Layer
Reverse Proxy: Nginx
Runtime: PHP 8.3-FPM

↓

Application & Data Layer
CMS: WordPress + WP Armour Honeypot
Database: MySQL 8.0

ลำดับการไหลของ Web Traffic



การจัดหมวดหมู่และรูปแบบการรันบริการของระบบ

Native Services on Host OS

- Direct Kernel-Level Protection: สกัดกั้นภัยคุกคามและบล็อก IP ขยะตั้งแต่ระดับ Firewall/Kernel ของ Host OS เพื่อตัดทราฟฟิกอันตรายก่อนจะหลุดเข้าไปถึง Container
- ครอบคลุม Layer 1-2: โครงสร้างพื้นฐานและระบบปฏิบัติการหลัก

Containerized / Sandboxed Services

- Environment Isolation & Security: จำกัดขอบเขตความเสียหาย หากแอปพลิเคชันถูกเจาะ ผู้บุกรุกจะถูกขังอยู่เฉพาะใน Container ไม่สามารถเข้าถึง OS หลักได้
- Ease of Maintenance & Scalability: สามารถอัปเดตเวอร์ชันซอฟต์แวร์ได้ง่าย ไม่กระทบต่อความเสถียรของระบบปฏิบัติการหลัก
- ครอบคลุม Layer 3-4: เว็บเซิร์ฟเวอร์, แอปพลิเคชัน และฐานข้อมูล

PERIMETER & NETWORK LAYER

การทำงาน

ด่านหน้าสุดของระบบ ทำหน้าที่จัดการชื่อโดเมนและควบคุมการเข้าถึงเครือข่ายคลาวด์ ป้องกันการเชื่อมต่อจากภายนอกที่ไม่ได้รับอนุญาต

เครื่องมือหลักที่ใช้

- DNS: DuckDNS
- Cloud Network: Azure NSG & IPset

รูปแบบและกลไกการป้องกัน

- Port Restriction: เปิดเฉพาะพอร์ตที่จำเป็น (80, 443, 22)
- Geo-Blocking: บล็อก IP ต่างประเทศ อนุญาตเฉพาะช่วง IP ในไทย เพื่อตัดวงจรบอทสแกนเนอร์ทั่วโลก

HOST & OS SECURITY LAYER



การทำงาน

ควบคุมความปลอดภัยในระดับระบบปฏิบัติการบน Azure VPS พร้อมระบบอัจฉริยะช่วยตรวจจับและสกัดกั้นผู้บุกรุก

เครื่องมือหลักที่ใช้

- VPS OS: Ubuntu 24.04
- Access Security: OpenSSH Server
- Defense & AI: Fail2Ban และระบบวิเคราะห์ Log ด้วย AI

รูปแบบและกลไกการป้องกัน

- Key-Based Auth: บังคับเข้าสู่ระบบ VPS ด้วย SSH Key แทนรหัสผ่าน
- Automated & AI Threat Detection: ใช้ Fail2Ban และ AI วิเคราะห์ Log แบบเรียลไทม์ เพื่อตรวจจับพฤติกรรมผิดปกติ และแบน IP ที่พยายามสุ่มยิงรหัสผ่านทันที

APPLICATION RUNTIME & WEB SERVER LAYER

การทำงาน

ด่านหน้าฝั่งเว็บเซิร์ฟเวอร์ คอยคัดกรองคำขอ (Request) จัดการความปลอดภัยการเข้ารหัส HTTPS และจำกัดขอบเขตการรันโค้ดสคริปต์ไม่ให้กระทบระบบหลัก

เครื่องมือหลักที่ใช้

- Web Server: Nginx Reverse Proxy 1.24.0
- Zend OPcache Engine
- Security Automation: Let's Encrypt / Certbot, Rate Limiting, Nginx Hardening
- PHP 8.3-FPM (FastCGI Process Manager)

รูปแบบและกลไกการป้องกัน

- SSL/TLS Termination: จัดการใบรับรองความปลอดภัย HTTPS
- Rate Limiting & Hardening: จำกัดอัตราการส่งคำขอเพื่อป้องกัน DoS, ซ่อน Token ระบบ และบล็อกทางผ่านลับ (wp-config.php, xmlrpc.php) ด้วยรหัส
- Execution Sandboxing: แยกการประมวลผลสคริปต์ PHP ออกจากเว็บเซิร์ฟเวอร์อย่างปลอดภัย
- Optimized Performance: เร่งความเร็วการประมวลผลโค้ดเพื่อลดภาระของทรัพยากรระบบ

APPLICATION & DATA LAYER

การทำงาน

ศูนย์กลางการประมวลผลแอปพลิเคชันและจัดเก็บข้อมูล ดักจับสแปมบอทระดับหน้าฟอร์ม พร้อมปิดกั้นฐานข้อมูลให้เชื่อมต่อได้เฉพาะภายในเท่านั้น

เครื่องมือหลักที่ใช้

- Database: MySQL 8.0
- Monitoring: AI Scanner & Discord Notification **Gemini AI model**
- CMS: WordPress Core & Astra Theme
- Spam Protection: WP Armour (Honeypot Anti-Spam)

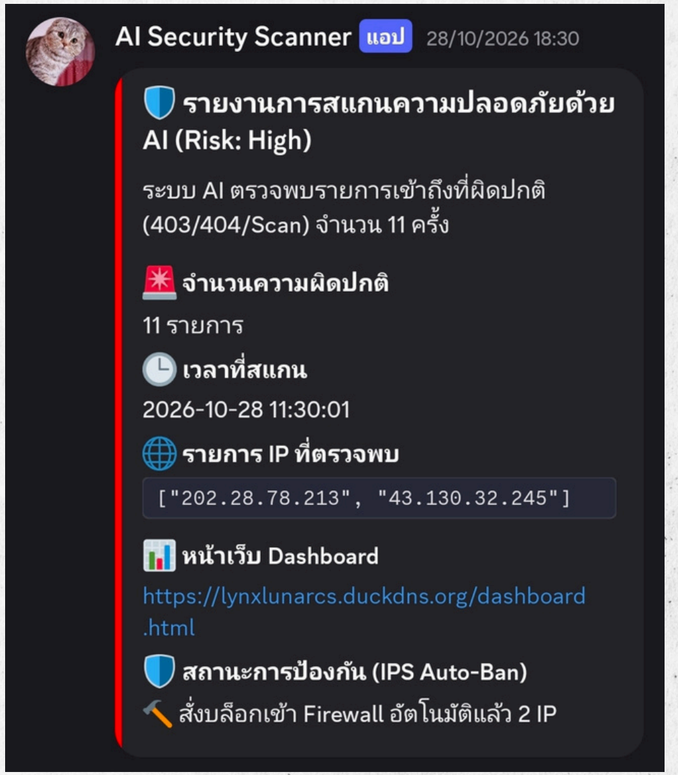
รูปแบบและกลไกการป้องกัน

- Isolated Database Architecture: ปิดกั้นไม่ให้ฐานข้อมูลรับการเชื่อมต่อจากภายนอกโดยตรง
- Real-time Alerting: ตรวจสอบความผิดปกติและส่งแจ้งเตือนตรงไปยัง Discord ทันทีเมื่อพบภัยคุกคาม
- Bot Barrier without CAPTCHA: ป้องกันสแปมคอมเมนต์และบอทหน้าเว็บโดยไม่ต้องพึ่งพา CAPTCHA ภายนอก
- Honeypot Trap Mechanism: สร้างฟิลด์กับดักที่ซ่อนจากสายตามนุษย์บนหน้า Login/Register เพื่อสกัดบอทอัตโนมัติ

เปรียบเทียบก่อนและหลังการติดตั้งระบบป้องกัน

หมวดหมู่การประเมิน	ก่อนปรับปรุง	หลังปรับปรุง	ผลการประเมินเชิงคุณภาพ
Transport Layer & TLS Security	3.5 / 5.0	5.0 / 5.0	ยกระดับการรับ-ส่งข้อมูลด้วยการบังคับใช้โปรโตคอลความปลอดภัยระดับสูงสุดเต็มรูปแบบ
Source Code & File Access Control	1.0 / 5.0	5.0 / 5.0	เสริมความปลอดภัยการประมวลผลผ่าน FastCGI Socket และปิดกั้นการเข้าถึงไฟล์สำคัญ
HTTP Security Headers	3.0 / 5.0	5.0 / 5.0	ติดตั้ง Security Headers (HSTS, CSP, X-Frame, Nosniff) เพื่อป้องกันการโจมตีทางเว็บ
Information Disclosure & Masking	2.5 / 5.0	4.5 / 5.0	ซ่อนข้อมูลระบบและบล็อกการเข้าถึงเอกสารลับหลังบ้านเพื่อไม่ให้ผู้บุกรุกสแกนหาช่องโหว่
Endpoint & Attack Surface Hardening	4.0 / 5.0	4.5 / 5.0	ปิดช่องทางการโจมตี ยอดนิยมโดยบล็อก XML-RPC และสกัดกั้นการสแกนหาชื่อผู้ใช้
Architecture & Nginx Configuration	1.5 / 5.0	5.0 / 5.0	ปรับปรุงโครงสร้าง Configuration ให้ถูกต้องตามไวยากรณ์ จัดแบ่งบล็อกการทำงานชัดเจนและปลอดภัย

ตัวอย่าง Discord Notification



รายชื่อสมาชิก

67160059	นางสาวกัญญาณัฐ จันทร์สูงเนิน
67160103	นายเมธาสิทธิ์ กองคำ
67160249	นายกิตติณัฏฐ์ ประพันธ์
67160418	นางสาวชิษณุภรณ์ เลืองวัน
67160091	นางสาวณัฐนรินทร์ น้ำเพ็ชร์
67160247	นายกัณพิทักษ์ ชลศิริวานิช
67160270	นางสาววิไลลักษณ์ แก้วขาว
67160421	นางสาวธนกร ลือภูวพิทักษ์กุล

Thank You!

Thank you for listening to our presentation. We hope this has helped clarify any questions you may have had about our project.